



Synthra Smart Contract Security Audit and Penetration Testing Assessment Report

Prepared on: Sep 30, 2026

rdauditors.com

Table of Contents

Confidentiality and Limitations	2
Introduction	3
Purpose of the Engagement	3
Assessment Activities Performed	3
1. Executive Overview	4
Security Scorecard	4
Critical Risk Summary	4
Strategic Summary	4
2. Executive Summary	5
3. Assessment Overview	6
3.1 Scope	6
3.2 Methodology	6
4. Security Assurance & Control Profile	7
4.1 Security Control Assessment	7
4.2 Security Requirements, Test Coverage and Evidence Reconciliation	8
4.3 Fresh Local Retest Results	9
5. Technical Findings & Vulnerability Analysis	10
5.1 Configuration, Operational Control & Governance	11
5.2 Custody, Accounting & Metadata Integrity	12
5.3 Checkpoints, Protocol Ordering & Test Assurance	12
6. Threat Scenarios and Cross-Contract Security Boundaries	15
7. Unified Risk Matrix	15
8. Remediation Roadmap	16
9. Conclusion	17
Appendix A — Findings Register	19
Appendix B — Historical Issues	22
Our Methodology	22
Disclaimers	24

Confidentiality and Limitations

This report is strictly confidential and intended solely for Synthra and its authorized representatives. Prepared by the RD Auditors, this security assessment concerns Synthra's Robinhood ↔ Arc LayerZero smart contract bridge and the supplied repository. It provides an evidence-limited, point-in-time view of reviewed controls and outstanding risks. No live deployed contracts, third-party DVN services, or issuer systems were independently tested. The report is not a certificate of security or a release approval.

Introduction

Purpose of the Engagement

The purpose of this engagement was to assess Synthra's Robinhood ↔ Arc bridge before release. RD Auditors is the named audit-report organization; the work documented here comprises source review of Robinhood → Arc deposits/minting, Arc → Robinhood burning/redemptions, LayerZero V2 endpoint and peer authentication, asset solvency, governance, metadata snapshots, and recovery operations. No individual auditor sign-off was supplied. The analysis records only supported findings and clearly identifies unexecuted retests.

Assessment Activities Performed

This assessment used source-code review, threat modeling, comparison of security documentation with implementation, fresh local Foundry unit/fuzz/invariant execution, coverage and gas reporting, fresh Slither 0.11.3 static analysis, offline configuration and RPC-stub simulations, and evidence reconciliation. No live-bridge exploitation, public network testing, or transactions involving real funds were performed.

- Threat Modeling and Trust Boundary Analysis
- Authorized Offline Penetration-Test Scenarios (not live exploitation)
- Manual Source-Code and Dependency Review
- Security Requirements, Test Coverage and Evidence Reconciliation

1. Executive Overview

Security Scorecard

Metric	Value	Rating
Confirmed exploitable Solidity defects	0 independently established	Local suites passed; not proof of absence
Verified off-chain / security-tooling gaps	3 open (P2-SG-01, P9-SG-01, P12-SG-01)	Low; remediation remains open
Fresh local security retest	Foundry 62/62 default + 62/62 audit	PASS — local unit/fuzz/invariant scope

Critical Risk Summary

No new exploitable Solidity implementation defect was independently established. Three Low-severity off-chain or security-tooling gaps are verified: P2-SG-01 (production confirmation policy is not an enforced approval gate), P9-SG-01 (incomplete operator recovery tooling and nonce-readiness classification), and P12-SG-01 (the Slither review gate rejects a successful zero-finding Slither 0.11.3 report). None demonstrates unauthorized minting or reserve release. Historical LZ-01 through LZ-04 are not reopened as new findings.

Strategic Summary

The application has layered peer and GUID authentication, required-DVN configuration, guarded vault accounting, hash-bound checkpoint recovery, and separated UI metadata. Fresh local testing used Foundry 1.5.1, Solidity 0.8.28, and Slither 0.11.3: the default and audit Foundry suites each passed 62/62 tests, the audit invariant completed 512 runs / 65,536 calls with 0 unexpected reverts, and Slither returned 0 detector results. Assurance remains limited because the 14 real-protocol fork tests were compiled but not executed, the full mutation campaign was not completed, and the current deployed state was not verified.

2. Executive Summary

The assessment of Synthra's Arc ↔ Robinhood bridge examined the uploaded source archive and the available historical review evidence. Its evidence-based results are:

On Robinhood, LayerZeroSourceVault escrows original ERC-20 assets and publishes net deposits for minting on Arc. Arc redemptions burn wrapped supply before authenticated release on Robinhood; checkpointing preserves stalled authentic claims. Raw principal remains separate from UI multiplier metadata.

This report retains 29 supported observations: three verified off-chain or security-tooling gaps, fourteen test coverage gaps, eight trust assumptions, and four informational observations. No confirmed exploitable Solidity defect was established.

Fresh local retesting completed with the pinned toolchain. Vendor verification passed for 58 files; Python tooling tests passed 44/44 with no skips; forge fmt and forge build passed; the default Foundry suite passed 62/62 tests; the audit profile passed 62/62 tests with six fuzz tests at 2,048 runs each and one stateful invariant at 512 runs / 65,536 calls / 0 unexpected reverts. Coverage measured 96.59% lines, 96.60% statements, 85.71% branches, and 98.53% functions overall. Slither 0.11.3 analyzed 28 contracts with 100 detectors and returned 0 detector results.

The most important unresolved technical validations concern authentic Endpoint/ULN checkpoint interleavings, very long nonce backlogs, original issuer seizure/freeze behavior, and extreme metadata conversion values. None is asserted as an independently reproduced financial exploit.

Release interpretation: This report is not a production-readiness approval. The fresh local Foundry suites and the Slither analyzer completed successfully as described in Section 4; however, the repository Slither review gate still fails on the valid zero-finding JSON (P12-SG-01), and no remediation patch was supplied for the open gaps, so no finding is marked Retest Passed. The 14 real-protocol fork tests were compiled but not executed; the full mutation campaign was not completed, and current deployment/configuration evidence remains outstanding.

3. Assessment Overview

3.1 Scope

Project: Synthra | Cross-chain bridge: Arc ↔ Robinhood. The assessment covered the supplied Solidity source, tests, documentation, scripts, and local tools. Production systems and real assets were excluded:

- Solidity: source vault, destination bridge, wrapped ERC-20, shared LayerZero Endpoint base, message library and interfaces.
- Cross-chain integration: outbound and inbound packets, peer/GUID, DVN and confirmation settings, checkpoints and message recovery.
- Financial model: entry fees, locked principal, wrapped supply, pending deposit/redemption claims and issuer/token edge behavior.
- Administration: bootstrap, guardian, timelock ownership, limits, treasury, deployment configuration and Python operational tooling.
- Evidence: fresh Foundry unit/fuzz/invariant, coverage and gas-report outputs; fresh Slither 0.11.3 JSON; local-fork compilation/listing; partial fresh mutation output; Python tooling tests; and historical validation records.

3.2 Methodology

The review used clearly separated, documented methods:

- Threat Modeling and Trust Boundary Analysis: Identifying high-impact attack vectors.
- Authorized offline simulated negative cases assessed verification-policy compatibility and nonce readiness; no live penetration attempts were carried out.
- Manual and Automated Source Review: Source-code and dependency inspection supplemented by fresh Foundry 1.5.1 / solc 0.8.28 execution and Slither 0.11.3 static analysis.
- Security claims were mapped to the actual Solidity and Python controls, checked against available tests, and classified by their independent verification status.

4. Security Assurance & Control Profile

4.1 Security Control Assessment

Security domain	Source assurance	Residual evidence need
Cross-chain authentication	Reviewed	Fresh local application tests passed; real Endpoint/ULN fork pending.
Asset accounting	Conditional	Fresh invariant passed; issuer freeze/seizure scenarios pending.
Checkpoint and recovery	Reviewed	Fresh local recovery tests passed; real Endpoint fork pending.
Governance and roles	Reviewed	Fresh governance tests passed; extended role/limit transitions remain.
Metadata display	Reviewed	Fresh metadata tests passed; broader multiplier/time fuzz remains.
Operational tooling	Open gap	P2-SG-01 / P9-SG-01 / P12-SG-01

Assurance note: Fresh local EVM execution was completed for the unit, fuzz, and invariant suites, and Slither 0.11.3 completed with 0 detector results. The repository Slither review gate still fails on that valid zero-finding report (P12-SG-01). Real-protocol fork execution was not performed because the repository runner uses public Robinhood/Arc RPC endpoints, and the full mutation campaign was not completed.

4.2 Security Requirements, Test Coverage and Evidence Reconciliation

Requirement group	Status	Primary outstanding evidence
Authenticated messages	Reviewed	Fresh local application tests passed; actual real-Endpoint/ULN fork execution remains pending.
Custody and solvency	Reviewed	Fresh invariant passed; issuer freeze/seizure and independent GUID-ledger scenarios remain pending.
Governance and operations	Pending	Remote limit coordination, timelock transitions, policy gate, and recovery commands.
Testing and assurance	Partially verified	Foundry/coverage/gas/Slither fresh; fork not executed; full mutation incomplete; P12-SG-01 gate defect open.

4.3 Fresh Local Retest Results

Test/tools	Fresh result	Scope/limitation
Vendor integrity	PASS — 58 files	Local vendored dependency hash verification.
Python tooling tests	PASS — 44/44; 0 skipped	Cast was available in the fresh toolchain.
forge fmt / build	PASS	Foundry 1.5.1 with local solc 0.8.28.
Default Foundry suite	PASS — 62/62	6 fuzz tests × 256 runs; invariant 128 runs / 8,192 calls / 0 unexpected reverts.
Audit Foundry suite	PASS — 62/62	6 fuzz tests × 2,048 runs; invariant 512 runs / 65,536 calls / 0 unexpected reverts.
Coverage	PASS	96.59% lines; 96.60% statements; 85.71% branches; 98.53% functions overall.
Gas report	PASS — 62/62	Fresh local execution completed.
Slither 0.11.3	PASS — 0 detector results	28 contracts / 100 detectors. Repository review gate failure is tracked as P12-SG-01.
Integration/fork suite	COMPILED ONLY — 14 tests	Not executed; public Robinhood/Arc RPC interaction was outside this local-only retest.
Mutation campaign	PARTIAL	Baseline passed; current retained rerun detected endpoint_authentication and source_eid before timeout.

5. Technical Findings & Vulnerability Analysis

Finding Status Register

Class	Finding IDs/count	Current status and evidence
Security gaps	P2-SG-01; P9-SG-01; P12-SG-01 (3)	OPEN — verified off-chain/tooling gaps; no remediation patch supplied
Test coverage gaps	14 entries (Appendix A.2)	OPEN — missing independent regression coverage
Trust assumptions	8 entries (Appendix A.3)	DEPENDENT — external configuration, issuer and governance
Informational	4 entries (Appendix A.4)	OBSERVED — no exploitable defect established

5.1 Configuration, Operational Control & Governance

[P2-SG-01] Production confirmation policy lacks a distinct approval gate

- **Severity:** Low | Confidence: High | Status: Open | Classification: Security Gap
- **Affected:** tools/check_layerzero_config.py:27–63; LayerZeroEndpoint.sol:91–138; DeployLayerZero.s.sol:67–101.
- **Description:** The offline checker verifies paired compatibility but not the selected production minimum of 15 confirmations.
- **Root cause/evidence:** local synthetic values 1, 14, and 15 all passed compatibility while productionApproved was false; the configured deployment templates use 15.
- **Impact:** preflight misuse could accept a policy departure; no affected live deployment shown.
- **Remediation:** add a separate production approval gate. Regression: reject 1/1 and 14/14 unless an explicit policy exception exists.

OPEN	P2-SG-01 Offline confirmation-policy gap; checker returns productionApproved=false. No remediation patch supplied. Retest not performed.
------	--

[P9-SG-01] Operator CLI omits authenticated recovery commands

- **Severity:** Low | Confidence: High | Status: Open | Classification: Security Gap
- **Affected:** layerzero_operate.py:61–74,95–107,196–201; layerzero_batch.py:32–95; Endpoint.sol:349–430.
- **Description:** CLI completion lacks first-class predecessor-commit, checkpoint, and executeCheckpointed operations.
- **Root cause/evidence:** an offline RPC stub marked committed nonce 2 ready without checking nonce 1; the CLI omits corresponding recovery actions.
- **Impact:** misleading readiness and delayed incident recovery; on-chain verification remains enforced.
- **Remediation:** simulation-first recovery commands and distinct verified, committed, nonce-blocked, checkpointed, and application-ready states; offline regression tests.

OPEN	P9-SG-01 CLI missing nonce/claim recovery verbs; simulated nonce readiness issue.
------	---

[P7-TA-01] Shared governance and guardian key exposure

- **Classification:** Trust Assumption | Medium operational severity | High confidence | Open
- **Affected:** DeployLayerZero._deploy:39–55; Endpoint.pause/unpause; OpenZeppelin TimelockController.

- **Description:** One governance EOA may hold proposer, executor, canceller, and emergency guardian powers.
- **Impact:** A lost or compromised key can affect multiple pairs; the original timelock still delays owner-only changes.
- **Recommendation:** separate authority, use monitored multisignature roles and document key recovery.

ASSUMPTION

P7-TA-01 | Governance key concentration, not unauthorized mint/withdrawal; timelock still protects owner-only changes.

5.2 Custody, Accounting & Metadata Integrity

No custody or metadata implementation vulnerability was independently reproduced. The related security invariants and remaining test coverage are described in the assurance and remediation sections.

5.3 Checkpoints, Protocol Ordering & Test Assurance

[P3-TG-02] Full real-protocol blocked-redemption checkpoint coverage

- **Classification:** Test Coverage Gap | Low | High confidence | Open
- **Affected:** Endpoint.complete/checkpoint/lzReceive:331-444; LayerZeroLive.t.sol:180-222.
- **Description:** mock tests cover a blocked redemption; real Endpoint checkpoint coverage primarily uses deposit ordering.
- **Impact:** real-protocol recovery interleavings remain untested, not demonstrated unsafe.
- **Remediation:** locally checkpoint blocked authentic redemption, resume and retry once; assert state after failed and successful paths.

OPEN

P3-TG-02 | Real Endpoint blocked redemption / replay integration still required.

[P4-TG-01] Stateful accounting excludes issuer reserve mutations

- **Classification:** Test Coverage Gap | Low | High confidence | Open
- **Affected:** Invariant.t.sol:52-180,208-243; SourceVault.deposit and _receiveMessage.
- **Description:** handler cannot donate, seize, freeze, negatively rebase or restore original-token balances.
- **Impact:** broader reserve-shortfall and liveness sequences remain unverified; current vault uses a fail-closed backing check.
- **Remediation:** separate issuer-fault handler and GUID-indexed claim accounting with external delta reconciliation.

OPEN	P4-TG-01 Issuer-controlled reserve mutations are not included in the stateful accounting invariants. Reproducible local issuer-fault tests remain outstanding.
-------------	--

[P8-TG-01] Real protocol integration is not a primary CI gate

- **Classification:** Test Coverage Gap | Low | High confidence | Open
- **Affected:** .github/workflows/audit.yml:17–20; tools/check.sh:10–24; integration/LayerZeroLive.t.sol.
- **Description:** 14 opt-in local-fork cases are separate from primary CI; mock pass does not establish authentic protocol integration.
- **Impact:** future changes might pass mock regressions but fail when integrated with actual ULN bytecode.
- **Remediation:** run a pinned read-only local protocol integration job as a required release check.

Existing safeguards: local fork harness and historical recorded results. Fresh local Solidity tests were performed and passed; real-Endpoint fork execution was not performed.

OPEN	P8-TG-01 Real Endpoint/ULN integration is opt-in, not a required primary CI gate. The 14-test integration suite compiled successfully, but no pinned real-protocol execution result is available.
-------------	---

[P12-SG-01] Slither review gate rejects a successful zero-finding report

- **Severity:** Low | Confidence: High | Status: Open | Classification: Security Gap
- **Affected:** tools/check_slither.py:18–23,36–40; tools/test_slither_gate.py:14–37; tools/check.sh:17–24.
- **Description:** Fresh Slither 0.11.3 completed successfully with 28 contracts, 100 detectors, and 0 detector results. It emitted a successful JSON report with an empty results object. The repository gate treats the absent results. detectors key as malformed and raises ValueError.
- **Root cause/evidence:** validate() requires results.detectors to be a list even when Slither returns results:{} for a successful zero-finding scan. Invoking tools/check_slither.py on the fresh report exits 1; tools/check.sh calls that gate at line 24 under set -e, so the release script cannot complete successfully unless the parser is fixed or bypassed.
- **Impact:** This is a fail-closed release-tooling defect that can block an otherwise successful audit pipeline or encourage manual gate bypass. No smart-contract exploit, false pass, or asset impact was demonstrated.

- **Remediation:** Accept an empty results object as zero detectors only when success is true and results is a dictionary; continue rejecting missing or malformed results. Add regression tests for both a valid zero-finding report and an incomplete analysis.
- **Regression-test status:** Open. The defect was freshly reproduced; no remediation patch has been supplied.

OPEN	P12-SG-01 Fresh Slither analysis passed with 0 detector results, but tools/check_slither.py rejects the valid zero-finding JSON shape. No remediation patch supplied; retest remains open.
------	--

6. Threat Scenarios and Cross-Contract Security Boundaries

Scenario	Security boundary	Existing evidence	Outcome
Unauthorized mint	Required DVNs; peer/GUID; onlyBridge	Fresh local Foundry; historical fork	No bypass reproduced
Unauthorized withdrawal	Authenticated redemption; locked checks	Fresh local Foundry	Not reproduced
Replay/checkpoint race	Consumed GUID; saved hash	Fresh local Foundry	Real-protocol retest pending
Confirmation mismatch	Two DVNs, selected 15 confirms	Offline check	P2-SG-01 Open
Nonce backlog	Commit and checkpoint	Fresh local Foundry + historical tests	Recovery CLI gap

7. Unified Risk Matrix

Classification	Informational	Low	Medium	High	Critical
Confirmed		None			
Security gaps		P2-SG-01; P9-SG-01; P12-SG-01			
Trust	External DVN	Limit policy	Admin key		

8. Remediation Roadmap

Priority 1: Resolve verified off-chain and security-tooling gaps

- P2-SG-01 — make 15-confirmation finality policy an explicit production-approval gate.
- P9-SG-01 — expose verified nonce and checkpoint recovery through the operator CLI.
- P12-SG-01 — update the Slither review gate to accept a successful zero-finding report while continuing to fail closed on incomplete or malformed analysis.

Priority 2: Reproduce authentic protocol and custody behavior

Reproduce peer, GUID, DVN, replay and checkpoint paths on pinned Endpoint/ULN bytecode.

- Extend independent financial invariants to include issuer seizure, freeze, and reserve restoration.
- Retest LZ-01 and LZ-02 nonce/backlog recovery under realistic gas constraints.

Priority 3: Close remaining assurance gaps

Exercise timelock changes, complete ownership migration, and asymmetric cross-chain limits.

- Test rejected native fee refunds, failed checkpoint rollback, and expired metadata recovery.
- Fuzz UI multiplier magnitude, rounding, dust and timestamp/sequence boundaries.
- Pin real-protocol integration forks and require them before release.
- Preserve the fresh Foundry, coverage, gas, and Slither evidence with the reviewed ZIP hash, and add complete fork and full mutation logs when those campaigns are authorized and completed.
- Maintain 29 reported entries and separately track historical LZ-01 through LZ-04.

9. Conclusion

No new exploitable Solidity implementation defect was independently established by the available source-level assessment.

Three verified Low-severity off-chain or security-tooling gaps remain open (P2-SG-01, P9-SG-01 and P12-SG-01). Fourteen test coverage gaps and external assumptions still require validation.

Current Security Posture: EVIDENCE-LIMITED — NO DEPLOYMENT APPROVAL Pre-deployment Verification Checklist:

#	Release requirement	Evidence to collect	Status
1	Exact reviewed revision	Commit and ZIP SHA-256	ZIP SHA-256 verified; Git commit unavailable
2	Protocol identities	Endpoint/ULN runtime bytecode	Unverified
3	Required DVNs	Effective verifier set	Unverified
4	Finality confirmations	15 or approved exception	P2-SG-01
5	Peer identities	Both sides, original token	Unverified
6	Custody and liabilities	Reserves and pending claims	Unverified live

7	Checkpoint behavior	Pinned real-protocol tests	Local tests passed; fork not run
8	Foundry test suite	Unit/fuzz/invariant logs	PASS — 62/62 default + 62/62 audit
9	Static analysis	Slither JSON + review	Slither PASS — 0 results; gate P12-SG-01
10	Operational recovery	Simulation-first CLI tests	P9-SG-01

Final Summary:

No new exploitable Solidity vulnerability was independently reproduced. Historical LZ-01/LZ-02 regression paths were exercised by the fresh local Foundry suites, but authentic real-Endpoint fork retesting remains outstanding. Fresh Foundry and Slither results do not replace the unexecuted real-Endpoint fork campaign or current deployment verification. Verify current contract code, governance, DVNs, reserves, and open claims before release.

Appendix A — Complete Reconciled Findings Register

A.1 Verified off-chain and security-tooling gaps

P2-SG-01 | Low | High confidence | OPEN — Confirmation policy approval. tools/check_layerzero_config.py:27–63 checks route compatibility but does not enforce the selected 15-confirmation policy. The validator explicitly returns productionApproved=false. Add a separate approved-policy preflight; test synthetic 1/14/15 values. No live misconfiguration proven.

P9-SG-01 | Low | High confidence | OPEN — Recovery operations in tools/layerzero_operate.py:61–74,95–107,196–201 and layerzero_batch.py:32–95 omit first-class proof-commit and checkpoint actions. A synthetic RPC test returned ready for nonce 2

without checking nonce 1. Add simulation-first recovery verbs and predecessor-aware status; run offline unit regressions.

P12-SG-01 | Low | High confidence | OPEN — Fresh Slither 0.11.3 completed successfully with 28 contracts, 100 detectors and zero detector results, but tools/check_slither.py:18–23 rejects the valid results: {} shape and causes tools/check.sh to exit 1. Remediate the parser and add a zero-finding regression test. No Solidity vulnerability was identified.

A.2 Open test coverage gaps — Low severity, High confidence

P2-TG-01 — Endpoint.commitVerifications/checkpoint:349–430. Large verified nonce backlog; progress bounded and unmeasured. Run 10/100/500/1,000 message simulation batches with gas, verification, and blocked intermediate claim measurements.

P3-TG-01 — Endpoint._checkOrigin/_checkGuid/lzReceive:282–326,432–458. Mock bad-origin checks exist; real-Endpoint field matrix incomplete. Test EID/sender/nonce/GUID/header alteration against pinned local ULN without changing supply or lock.

P3-TG-02 — Endpoint.complete/checkpoint/executeCheckpointed:331–444; LayerZeroLive.t.sol:180–222. Mock blocked-redemption tests exist; real protocol competing delivery is incomplete. Test checkpoint, blocked withdrawal, recovery, and replay exactly once. Includes former P5-TG-03.

P4-TG-01 — Invariant.t.sol:52–180,208–243. Existing handler exclude donations, negative rebasing, freeze, and seizure. Add fault-injected issuer mock, independent GUID ledger, externally adjusted reserve conservation, and retry invariants.

P4-TG-02 — Endpoint._send:276–280; Bridge.t.sol:208–275. Explicit rejecting-native-refund receiver regression absent. Overpay an outbound transaction and require rollback of custody, fees, burns, liability, and nonce on refund failure.

P5-TG-01 — Endpoint.checkpoint:399–413; Verification.t.sol:65–88. Checkpoint failures expect revert but not every exact state. Assert payload commitment, lazy nonce, checkpoint hash, consumed GUID, and token amounts remain unchanged after failed clears.

P5-TG-02 — WrappedAsset.applySnapshot:60–93; Endpoint.checkpoint:399–430. Combine stale checkpointed metadata, failed deferred execution, newer valid snapshot, and consumption of obsolete snapshot. Assert no overwrite of the latest multiplier.

P7-TG-01 — TimelockController role scheduling; Governance.t.sol:49–160. Test updateDelay, grantRole/revokeRole, cancellation, unauthorized callers, and the minimum delay in a genuine local timelock environment.

P7-TG-02 — Endpoint.transferOwnership:185–188; OpenZeppelin Ownable2Step. Exercise nomination, rejected outsider acceptance, new-owner acceptance, cancellation, old-owner loss

of rights, and irreversible bootstrap closure.

P7-TG-03 —

Endpoint.prepareInboundMaxTransfer/setMaxTransfer/_transfer:198–212,460–471. Test asymmetrically increased outbound limit against the unprepared receiver; ensure the authenticated claim stays retryable after the inbound increase.

P7-TG-04 — Endpoint.activate/pause/_closeBootstrap:161–188,214–233. Combine initial setup pause, one-time bootstrap activation, guardian repause, and rejected further bootstrap unpause.

P8-TG-01 — .github/workflows/audit.yml:17–20; tools/check.sh:10–24. Local-fork integration is opt-in rather than the primary CI release gate. Introduce deterministic, authorized local protocol integration required before release.

P8-TG-02 — integration/LayerZeroLive.t.sol:23–29. Fork setup lacks pinned block numbers in createSelectFork. Supply explicit approved fork heights, log runtime hashes, and verify reproducibility against fixed inputs.

P8-TG-03 — Bridge.t.sol:105–126; Security.t.sol:232–244; Metadata.t.sol:65–82. Multiple fuzz tests use finite seed-modulo cases. Supplement with actual quantity, time, multiplier, nonce, and permutation property generators.

A.3 Operational trust assumptions — not proven Solidity vulnerabilities

P3-TA-01 — Endpoint/ULN runtime and DVN integrity are external assumptions. Immutable app settings do not independently certify external bytecode. Verify configured production identities using separately authorized state evidence.

P3-TA-03 — Two mandatory DVNs create liveness dependency. A missing required attestation cannot be bypassed by checkpointing; establish verifier availability monitoring and a separately reviewed migration plan.

P3-TA-02 — One-time peer selection requires accurate counterpart identity.

Endpoint._setPeer:150–159 restricts setter authority but cannot independently prove a remote deployment. Requires two-chain activation preflight.

P4-TA-01 — Original issuer can freeze, seize, or change reserve behavior.

SourceVault._receiveMessage:100–118 checks aggregate backing and exact transfers, but cannot force original issuer transfers; monitor locked and balance deltas.

P6-TA-01 — Metadata accuracy and publication cadence rely on issuer values; a snapshot may remain fresh by age while out of date by content. Track source changes and publish authenticated updates promptly.

P7-TA-01 — Governance/guardian roles may depend on the same key. Initial timelock protects owner-only calls; consider multisignature governance, separate guardian and recovery operations.

P7-TA-02 — Authorized timelock delay reduction or bridge ownership transfer can change future administration protections. Monitor updateDelay and ownership/role events; treat initial 48-hour delay as a deployment guarantee, not permanent.

P7-TA-03 — Cross-chain transfer ceilings must be raised in a coordinated sequence. Monitor receiving-side prepareInboundMaxTransfer before permitting larger outbound messages.

A.4 Informational observations

P4-INFO-01 — Unallocated direct original-token donations and accidental wrapped transfers to the bridge may become stranded; no administrative sweep is present by design. Warn users against direct contract transfers.

P6-INFO-01 — Raw snapshot() data can be stale. UI converters use observation-age checks and floor rounding; finance integrations should use raw balanceOf, totalSupply and vault liabilities instead of scaled displays.

P8-INFO-01 — Historical evidence remains incomplete: 132 present SHA-256 entries match, but 12 generated artifacts are absent. Fresh local Foundry and Slither execution now independently supports the unit/fuzz/invariant, coverage, and static-analysis claims for the supplied ZIP; historical fork execution remains independently unverified.

P8-INFO-02 — The historical report records 67 targeted mutation detections. A fresh mutation rerun established a passing baseline, and the current retained evidence detected endpoint_authentication and source_eid before the execution window ended. The complete campaign did not finish, so no fresh 67/67 claim is made; the historical 67/67 result remains historical evidence.

Appendix B — Historical Issue Reconciliation

LZ-01 — Source-mitigated via Endpoint.commitVerifications and completeWithVerifications:349–393. The dedicated local nonce/ordering regressions passed within both fresh 62-test Foundry runs. Authentic real-Endpoint fork execution remains pending.

LZ-02 — Source-mitigated via checkpoint and executeCheckpointed:395–430. Local checkpoint/recovery regressions passed within both fresh 62-test Foundry runs. Very large backlog stress and blocked-redemption real-protocol fork execution remain pending.

LZ-03 — Targeted regression tests passed in the fresh Foundry suites. The fresh mutation campaign baseline passed, and the current retained evidence detected endpoint_authentication and source_eid before timeout, but the complete campaign was not completed; the historical

67-mutation result is therefore not represented as a fresh full rerun.

LZ-04 — Two required DVNs and a 15-confirmation policy are documented in finality configuration; no current live verification was conducted. Separate offline policy gap is P2-SG-01.

Evidence and testing — Fresh local toolchain: Foundry 1.5.1, solc 0.8.28, and Slither 0.11.3. Vendor verification passed for 58 files. Python tooling tests passed 44/44 with no skips. forge fmt, forge build, default 62/62 tests, audit-profile 62/62 tests, coverage, gas report, and Slither all completed successfully. Slither returned 0 detector results. Integration/fork tests compiled, and 14 tests were listed but were not executed. The mutation baseline passed; the current retained rerun detected endpoint_authentication and source_eid before timeout, and the full mutation campaign was not completed. No real-fund, live-bridge, or production-contract interaction occurred.

Review identity — source archive: synthra-rwa-main.zip; SHA-256:
90be3fdf87be973d84c126d3d6fe95824542f52c7f0e2e4b4b58cc507af38036. Exact Git commit unavailable because the ZIP omits .git metadata.

Our Methodology

This assessment is based on source tracing, documentation, and test-assertion inspection, offline Python simulations, and reconciliation of historical evidence. No production smart contracts or real funds were touched. The reported findings retain their evidence-based severity and status.

- **Threat modeling reviewed custody, message authentication, peer and GUID identity, and governance authority.**
- **Offline local scenarios tested synthetic confirmation-policy values and RPC nonce readiness, not production exploits.**
- **Source analysis inspected LayerZero contracts, mock tests, fork harness design, and deployment tooling. Fresh Slither 0.11.3 analysis completed successfully with 0 detector results in the configured production scope.**
- **Evidence reconciliation: 132 present files and 86 mutation inputs matched recorded hashes; 12 historical generated artifacts remain absent. Fresh Python tooling tests passed 44/44, both Foundry profiles passed 62/62, coverage and gas reporting completed, and Slither returned 0 detector results. The fork suite compiled but was not executed; the mutation campaign was only partially rerun.**

Disclaimers

Confidentiality: This security assessment and its findings are classified as confidential and are intended solely for Synthra and its authorized representatives. The report was generated by RD Auditors. No individual auditor identity or formal sign-off has been independently established.

Scope Limitations: The findings relate to the provided Synthra Arc ↔ Robinhood repository, its listed dependencies, configuration, documentation, and authorized local simulations only. No production blockchain contracts, live third-party services, or customer funds were tested.

Accuracy Limitations: Security audits and penetration-testing assessments represent point-in-time evidence. No assessment guarantees the absence of all vulnerabilities. Fresh local Foundry, coverage, gas-report, Python, and Slither results are distinguished from historical evidence. The real-protocol fork suite was not executed, the full mutation campaign was not completed, and current production deployment state was not independently verified.

Liability Limitations: As stated in the reference report's disclaimer, RD Auditors does not accept responsibility for financial loss, business interruption, data breaches, or reputational damage arising from identified or undiscovered vulnerabilities, except where separate written engagement terms apply. This point-in-time report is not a warranty. We did not independently verify the current deployment, issuer, or DVN state; the exact Git commit was unavailable in the supplied ZIP.

Intended Use: This RD Auditors report is provided to inform Synthra's internal engineering review, risk prioritization, and remediation decisions. It does not constitute a certification, compliance attestation, legal opinion, warranty, or production-launch approval.



Email: info@rdauditors.com

Website: www.rdauditors.com

